

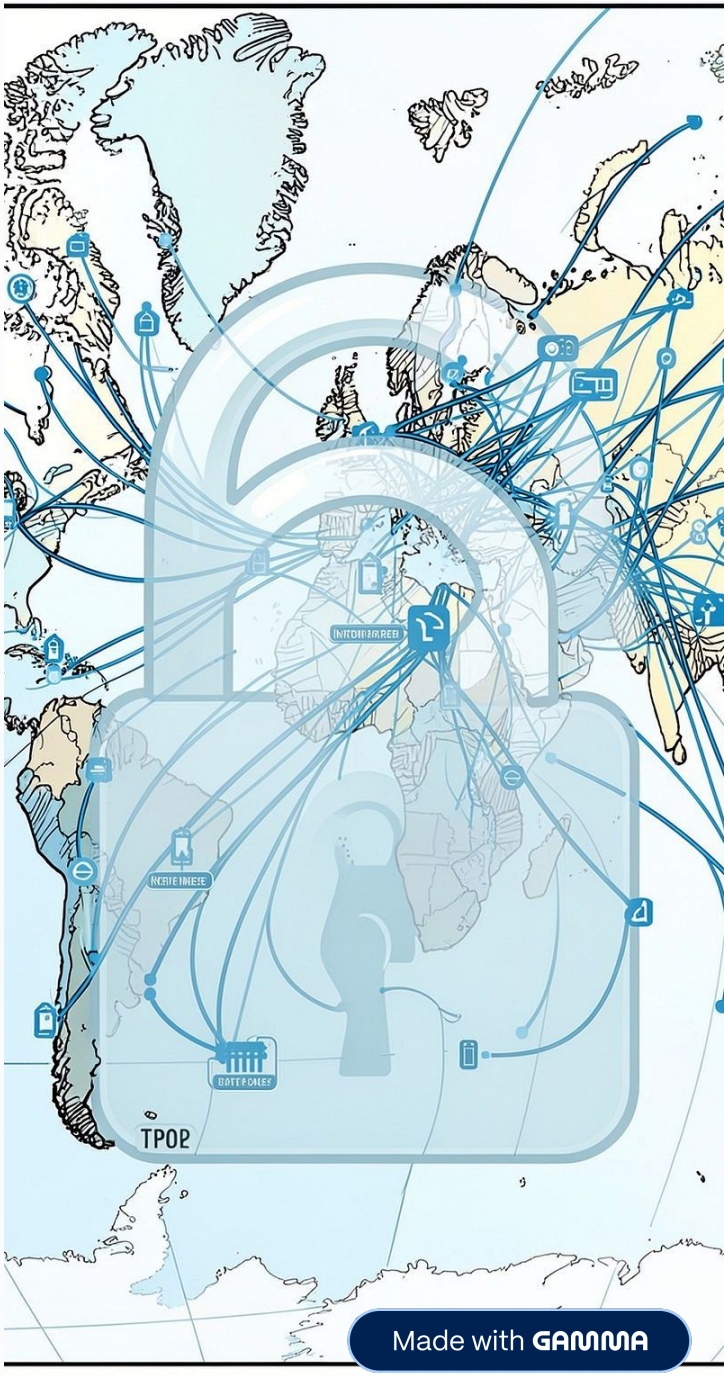
SMTPS: Secure Email Communication Using TLS

Concise guide to protecting SMTP traffic with TLS, avoiding downgrade attacks, and combining transport and message-level safeguards for real-world security.

Made with GAMMA

The Problem SMTPS Solves: Plain SMTP in Transit

- Email in transit can be eavesdropped or modified if the transport isn't protected.
- TLS protects confidentiality and integrity of SMTP commands and message content while traversing untrusted networks.
- Without enforced transport security, opportunistic delivery often leaves messages exposed.



Made with GAMMA

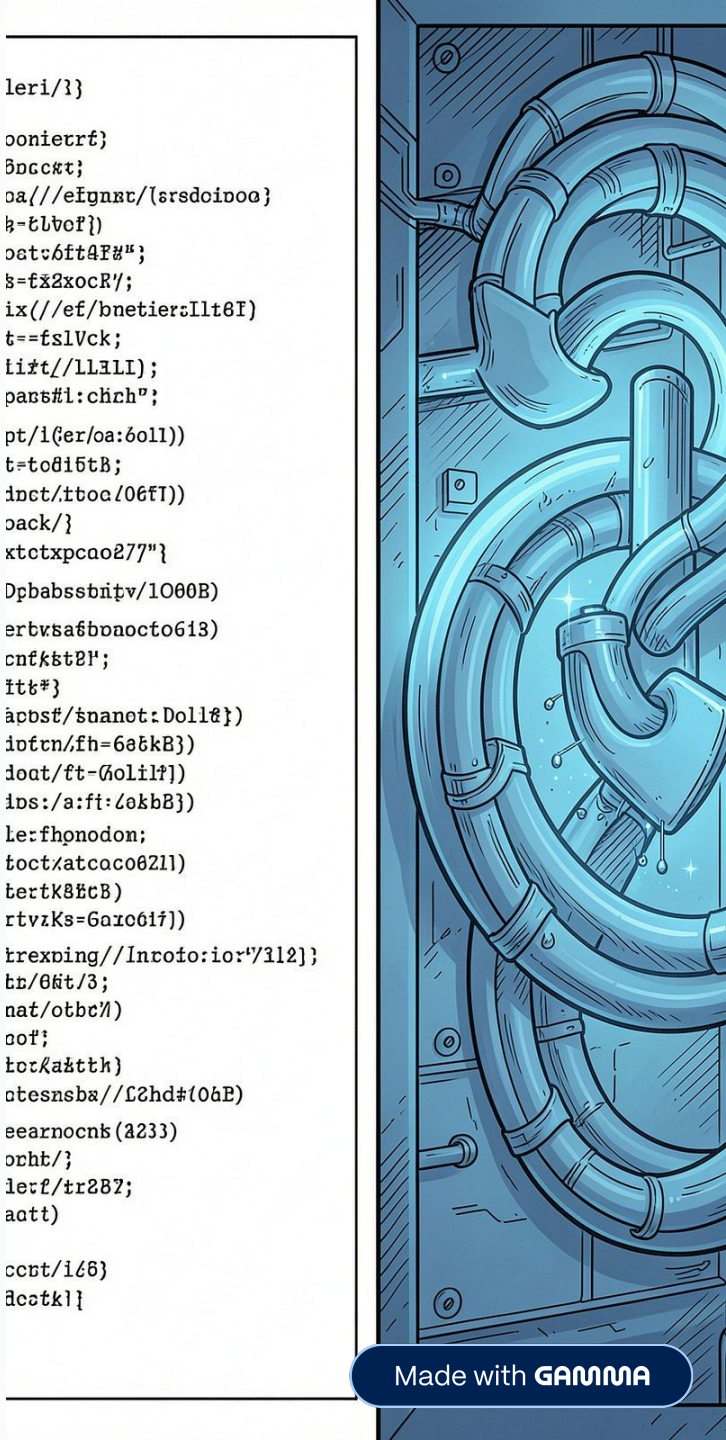
SMTPs vs STARTTLS: Two Ways to Turn On TLS

STARTTLS (Opportunistic)

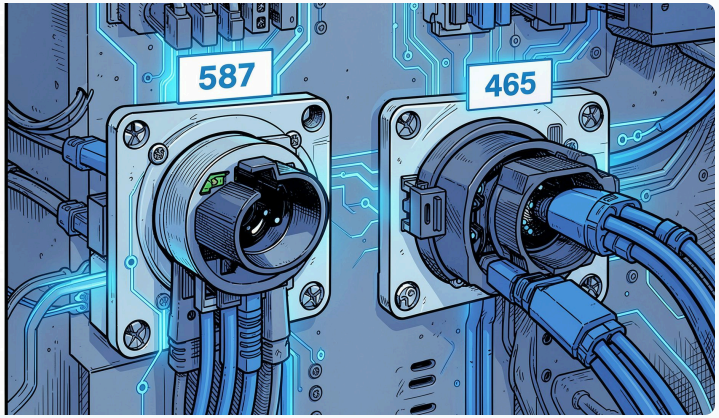
Upgrades an existing plaintext SMTP session to TLS on the same TCP connection. Useful, but exposes an initial plaintext phase and is vulnerable to active downgrade.

SMTPS (Implicit TLS)

SMTP is wrapped in TLS from connection start — no plaintext window. Eliminates the visible STARTTLS advertisement that attackers can strip.



Made with GAMMA



The Port Story: 587 vs 465 (and why it matters)

Port selection influences TLS behaviour and attacker surface:

- **Port 587 (submission)**: Clients connect in plaintext and typically use STARTTLS after the server advertises it.
- **Port 465 (SMTPS)**: Connection is implicit TLS — the TLS handshake happens immediately, reducing plaintext exposure.
- RFC 8314 (2018) recommends implicit TLS for submission/access where feasible to reduce downgrade risk.

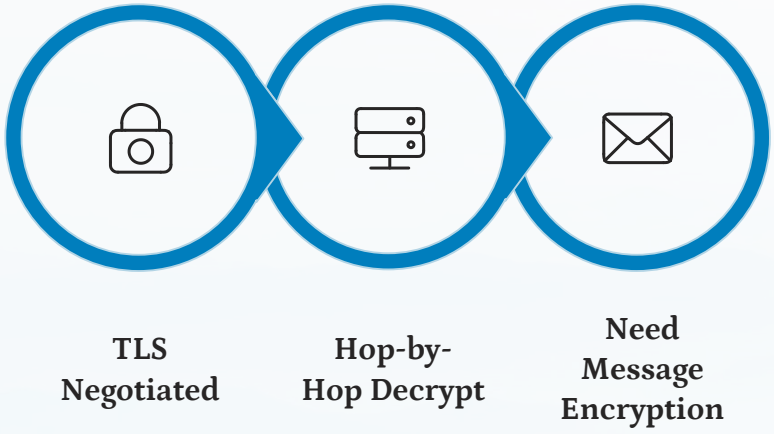
Made with GAMMA



How the Attack Works: STRIPTLS and Downgrades

STARTTLS advertises itself in clear text. An active attacker can remove that advertisement (STRIPTLS) so the sender continues in plaintext. Many clients or MTAs "fail open" and keep delivering without TLS, allowing interception. MITM may also tamper with certificate negotiation to weaken or nullify protection.

Made with GAMMA

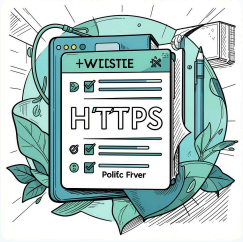


What TLS Actually Gives (and its limits)

- TLS provides authenticated encryption: SMTP commands and message bodies travel inside TLS records once negotiated.
- Transport is hop-by-hop: intermediate MTAs decrypt and re-encrypt, so transport TLS does not equal true end-to-end secrecy.
- To achieve end-to-end confidentiality and non-repudiation, use message-level schemes such as S/MIME or OpenPGP in addition to TLS.

Made with GAMMA

From Opportunistic to “Always Secure”: MTA-STS and DANE



MTA-STS (RFC 8461)

Host a policy over HTTPS that tells senders to require TLS for your domain. Helps prevent strip-and-deliver downgrade attacks by signalling "encrypt or don't deliver".



DANE + DNSSEC (RFC 7672)

Pin SMTP server certificates via DNS TLSA records protected by DNSSEC. Provides cryptographic binding between DNS and TLS keys — stronger verification when DNSSEC is deployed.

Combined, these mechanisms move mail systems from opportunistic encryption toward verified, enforced transport security.

Made with GAMMA



Conclusion: A Practical Secure Email Transport Strategy

1. Enable and prefer TLS everywhere — strong cipher suites and timely, CA-signed certificates.
2. Use SMTPS (implicit TLS) at submission edges where appropriate to avoid plaintext windows.
3. Adopt MTA-STS and DANE where possible to prevent downgrade and validate server credentials.
4. For true end-to-end confidentiality, layer message-level encryption (S/MIME or OpenPGP) on top of transport protections.

Practical priority: harden transport first, then introduce message-level encryption for sensitive workflows.

Made with GAMMA